



7

Security issues fixed

16/16

Test cases passed

86

Automated tests passing

0

Regressions

- ✓ **Admin data endpoints locked**
The “list everyone’s data” page now needs a secret key; with no key it is disabled (fail-closed).
- ✓ **Public demo locked too**
The same admin endpoints return 403 on the hosted demo, not just locally.
- ✓ **Anti brute-force throttle**
Per-client + global rate limit on face matching blocks mass “face-fishing”, even behind shared proxy IPs.

- ✓ **Real personal data purged**
Found 3 real passports (+ face templates) stored and re-seeding; deleted the source and wiped the store.
- ✓ **Face-login hides passport details**
On a match it returns first name + a masked document number (PA•••••43); no full name / DOB / expiry.
- ✓ **Gesture step can’t be faked**
One-time server-issued token (replay-proof) + can’t skip ahead before the server-verified liveness step.

HOW WE PROVED IT

- ✓ **86 automated tests**
The computer re-checks every rule — fast and repeatable (one command).
- ✓ **16 documented test cases**
Each with objective, steps, expected vs actual result — all PASS.
- ✓ **Live checks on the deployed demo**
Poking the real site returns “blocked”: 403 / 401 / 429.

NEXT ON THE PRODUCTION ROADMAP

- **Encrypt biometric templates & PII at rest**
with proper key management (KMS)
- **API authentication**
for verification + face-login, when accounts / partners are added
- **Full server-side gesture verification**
a backend hand model instead of trusting the client
- **Distributed rate limiting + audit logs**
for multi-instance production scale